CÉDULA DIGITAL DOMINICANA · PROOF OF CÉDULA

Clave de prueba en producción. Raíz de confianza inexistente.

ACCIÓN URGENTE. Todas las cédulas de producción que examinamos llevan una firma que respalda su garantía anticlonación hecha con una **clave de prueba del proveedor, RSA-1024**, y la raíz de confianza de la JCE **no existe en línea**. Más de 4 millones de cédulas ya se entregaron, de 8.7 millones habilitadas. Estas fallas deben corregirse ya, y juntas.

Alcance: cédulas de producción emitidas desde principios de 2026 hasta septiembre de 2026, examinadas con permiso de sus titulares, con información pública y protocolos ICAO/ISO documentados. Sin datos de ciudadanos. La Junta Central Electoral (JCE) ya fue informada de los hallazgos más graves antes de esta publicación.

HALLAZGOS

HALLAZGO 1 ■ DEFECTO CONFIRMADO — Clave de desarrollo RSA-1024 en producción

Qué falla. `EF.CardSecurity`, el objeto que sostiene la garantía de que el chip no es un clon, está firmado por un Document Signer **RSA-1024** de procedencia **desarrollo** (`cryptovision/development`) en **todas** las tarjetas de producción examinadas. RSA-1024 está obsoleto y es alcanzable por un adversario con recursos de Estado. Una clave de desarrollo, además, puede venir en el SDK o el material de muestra del proveedor: entonces es prácticamente pública. **Falla de auditoría:** una clave de pruebas pasó a producción sin ser detectada.

Qué hacer ya. Determinar de inmediato si la clave privada existe en material del proveedor y **tratarla como comprometida hasta demostrar lo contrario**. Sustituir el firmante por uno de producción exclusivo de la JCE. Investigar cómo una clave de desarrollo llegó a producción.

HALLAZGO 2 ■ BRECHA DE CONFIANZA CONFIRMADA — La raíz de confianza de la JCE no existe en línea

Qué falla. El ancla CSCA publicada, `https://ca.jce.gob.do/csca`, devuelve **NXDOMAIN**: el nombre no resuelve. La lista de revocación está en el mismo host inexistente. Un verificador no puede anclar la cadena del firmante de identidad (`EF.SOD`) ni recibir una revocación. La firma está intacta; falta una raíz alcanzable y fijada que demuestre quién firmó.

Qué hacer ya. Publicar el CSCA y la CRL en una ubicación alcanzable, **fijar el ancla** en todos los verificadores y exigir que **fallen cerrados** ante un firmante que no puedan anclar.

CÓMO SE COMBINAN: TARJETAS CLONADAS ACEPTADAS

Modelo de amenaza posible, construido a partir de los dos hallazgos; no se ejecutó contra ningún sistema real.

Quien tenga una cédula en las manos, aunque sea un momento, podría leer sus datos con el CAN impreso en ella. Si obtuviera la clave del Hallazgo 1, podría firmar un reemplazo de `EF.CardSecurity` y construir un clon que **supere Chip Authentication**, la verificación que existe precisamente para detectar clones. Dado el Hallazgo 2, los verificadores que obtienen la raíz en tiempo de ejecución podrían aceptar un firmante sin ancla. **En este modelo, cualquier aplicación que confíe en el certificado de desarrollo, o acepte un firmante que no puede anclar, podría ser engañada con una tarjeta clonada o editada.**

POSIBLES ATAQUES

Modelos con precondiciones explícitas; ninguno se ejecutó contra sistemas reales.

	Ataque	Requiere
A	**Clon que supera Chip Authentication.**	La clave del firmante de desarrollo (del material del proveedor o factorizando RSA-1024), una copia de los datos legibles y un verificador que acepte ese firmante.
B	**Aceptación con falla abierta.** Un verificador que no puede obtener la raíz acepta un firmante sin ancla, incluso falsificado o autofirmado.	Solo un verificador escrito así. No se compromete ninguna tarjeta.
C	**Fraude aguas abajo:** KYC, incorporación de clientes y quioscos que aceptan un objeto de seguridad fabricado.	Que el sistema omita la autenticación pasiva completa con anclaje.
D	**Firmante imposible de revocar.** Si la clave se filtra, no hay forma efectiva de avisar a los verificadores. El certificado es válido hasta 2079.	Clave filtrada o rota.
E	**Compromiso de clave sin conexión e indetectable.** Usar la clave no requiere tocar ninguna tarjeta ni sistema de la JCE: no deja rastro.	Solo la clave y un verificador que acepte el firmante.

ACCIONES URGENTES

1. **Ahora:** confirmar si la clave privada de desarrollo está en manos del proveedor o en su SDK, y tratarla como comprometida mientras tanto.
2. **Ahora:** restaurar el CSCA y la CRL en una ubicación alcanzable y fijar el ancla en todos los verificadores. Corregir la clave y publicar el CSCA **deben hacerse juntos**.
3. **Ahora:** corregir la personalización de las tarjetas aún no emitidas; establecer si las ya emitidas pueden actualizarse; reemitir solo lo que no pueda corregirse. No esperar a la auditoría para esto.
4. **Verificadores:** auditar los que consumen la tarjeta (app de la JCE, lectores de terceros, KYC, quioscos): fallo cerrado, ancla fijada, rechazo del firmante de desarrollo.
5. **Auditoría:** encargar una auditoría criptográfica independiente y completa, dirigida por criptógrafos calificados e independientes del proveedor y respaldada por la JCE, con acceso a registros de claves, perfil de tarjeta, software de personalización y lecturas presenciadas de tarjetas de distintos lotes. Decidir la reemisión general con sus resultados.

LÍMITES

Hallamos todo esto desde afuera, con información pública: sin acceso a registros de la JCE, ceremonias de claves, hardware de firma ni documentación del proveedor. **No podemos descartar otras fallas.** Las pruebas sobre la tarjeta que no tuvieron éxito (escribir datos por CAN/PACE, alterar el MAC o degradar Secure Messaging, falsificar `EF.SOD` con la clave RSA-1024) describen lo que probamos, no son una garantía. No cubre las vías con credenciales del emisor ni la fuerza bruta de PIN. Esta recomendación no está condicionada a ninguna contratación de FACTOR Inc., que ofrece servicios de auditoría criptográfica (interés comercial declarado).

FACTOR Inc. · team@projectfactor.io · projectfactor.io · github.com/ProjectFactor/auditoria_criptografica

ANEXO: FICHA TÉCNICA DEL CERTIFICADO RSA-1024

Datos del certificado Document Signer que firma `EF.CardSecurity` en las cédulas de producción examinadas.

Campo	Valor
IDENTIFICACIÓN	
Función	Document Signer (DS) de `EF.CardSecurity`
Versión	3 (0x2)
Número de serie	`70:01:22:04:88:CD:EF:EA:33:B2:6B:05:9A:28:63:7C`
Asunto (Subject)	`C=DE, O=cryptovision, OU=development, CN=DS`
Emisor (Issuer)	`C=DE, O=cryptovision, OU=development, CN=CSCA`
Válido desde	`2019-12-31 23:00:00 UTC`
Válido hasta	`2079-12-31 23:00:00 UTC` (60 años)
CLAVE PÚBLICA	
Algoritmo	`rsaEncryption`
Tamaño de la clave	**1024 bits** (309 dígitos decimales)
Exponente público	65537 (0x10001)
Módulo (hex)	`a1c50ddf96ca191dc25bdc36dfebc9d0d92119bf29715715188a015693e08593 b5e3dc1baf0d514520f78a6288786247651ead3e3888de1e8883942a4266e468 978e2184f3985a6b3975f599fc802dd7404e7a4552f09fa5b6d456f3cca96ec5 1058c1f8429f370ff23e7888c2fb7cfd9fd3a320b1eb5f58fe019c45807bbc69`
FIRMA DEL CERTIFICADO	
Algoritmo de firma	`sha256WithRSAEncryption`
Longitud de la firma	2048 bits (256 bytes)
Valor de la firma (hex)	`6c4a4dba4ff94923697e22c9145621317a29e4eb183bddfb4e5f17e2142a3f50ecf69ccab26b4fce4f2926 aeed9b9cde8d39a8861cefad1d6f7feb3cb4b02e1189bd2ea43a2dc59cb204094af960183936f3552710f0 7dcd8a2560b88db021c3b00ace1b18b635eaefe1e07379120399bb10ce59e26e02a684bb92dbfdfb37d193 70f26df40ce3b3285b6ffa083737df71e3729efacb544d2996564f2fafea74da34ab6d6768e1ac242cfdcb 219f2b724ce4842829a9b7cafb9779fdb64498d8698543858e54f81b6195e114ca47014a71cbaba767e0d8 4e43cf9538a4e74982f378a7f7b4295f5d1870ad4d54d164f3dd24089a58cccf57a48ef0c754dd0320`
EXTENSIONES X.509 v3	
Authority Key Identifier	`64:1F:97:8A:63:AE:1B:40:71:74:E9:6E:35:66:AF:34 7F:ED:3B:20`
Key Usage (crítica)	`Digital Signature`
Subject Key Identifier	Ausente
CRL Distribution Points	Ausente (sin vía de revocación)
Authority Information Access (OCSP)	Ausente
HUELLAS Y TAMAÑO	
SHA-256 (DER)	`4E:B2:79:36:EE:EE:48:8C:84:09:04:4D:8D:B3:FF:22 21:01:55:44:3B:89:DB:7E:4B:21:AE:E2:F9:57:04:E2`
SHA-1 (DER)	`9E:99:EF:6D:5D:8F:CE:53:37:12:53:99:B7:71:4B:F1 34:7A:90:DE`
Tamaño DER	719 bytes
USO Y PRESENCIA EN LA CÉDULA	
Objeto que firma	`EF.CardSecurity` (1,225 bytes)
SHA-256 del objeto	`09b130edd80f8cf20ac9ecce8bcc5f03 dd59e7a03c3e61243e0a045c1bdde7bf`
Contenido firmado	22 bytes: declaración PACE (`id-PACE-ECDH-GM-AES-CBC-CMAC-256`)
Procedencia	**desarrollo** (`cryptovision/development`)
Presente en	**Todas** las tarjetas de producción examinadas
Estado del algoritmo	**RSA-1024: obsoleto**